

**Manipulating the Help Desk: A Comparative Analysis of Group Behavior and Persuasion
in the 2020 Twitter and 2023 MGM Resorts Social Engineering Attacks**

Aditya Nakadi

School of Public Policy, Georgia Institute of Technology

CS 6768: Psychology of Cybersecurity

Professor Courtney Crooks

April 2026

Abstract

Social engineering attacks targeting organizational help desks have driven some of the most significant security incidents in recent years, including the July 2020 Twitter breach and the September 2023 attack on MGM Resorts International. In both cases, attackers gained access not through technical vulnerabilities but through short phone interactions with employees. This paper argues that such incidents are usually presented as individual mistakes or lack of training on the part of the employees, while both attacks involved the use of well-known behaviors by group members in an organization, such as the influence of authority and time pressure, in-group trust, deferral to positions, and diffused responsibility among others. Using the two cases above, this paper uses the psychological concepts to show how social engineering exploits employee behaviors and attitudes under normal working circumstances to make employee compliance likely.

Keywords: social engineering, group behavior, Cialdini, in-group trust, authority bias, diffusion of responsibility, help desk vishing

Introduction

Social engineering is often treated as a problem of individual failure. When employees are deceived into revealing credentials or granting access, explanations typically focus on poor judgment, lack of awareness, or insufficient training. While these factors play a role, they do not fully explain how some of the most significant security breaches in recent years have occurred.

Two examples highlight this difference. In July 2020, attackers were able to breach internal systems belonging to Twitter by masquerading as IT staff and tricking employees into visiting a fraudulent virtual private network login site, resulting in the compromise of high-profile user accounts and promoting a cryptocurrency fraud scheme (NYDFS, 2020). In September 2023, a threat actor from the hacking group named "Scattered Spider" posed as an employee from MGM Resorts and contacted the organization's IT support team, acquiring administrative credentials in minutes, leading to disruptions and monetary losses amounting to one hundred million dollars (CISA & FBI, 2023).

Employees responded in ways consistent with the expectations and pressures of their roles, in line with research showing that social engineering succeeds when target behavior aligns with normal role expectations rather than failing on individual judgment (Steinmetz et al., 2021). In both situations, the initial compromise did not occur due to any form of technical exploitation. The employees granted access because of regular interactions with people whom they assumed to be authorized. The examples above highlight one structural aspect that may remain unnoticed when assessing the situation after the incident. In both scenarios, employees were not irrational nor unaware.

This paper suggests that the success of the attacks could be explained by collective psychology, not an individual mistake. More precisely, both incidents benefitted from four

interacting processes: persuasive cues (authority and immediacy), in-group bias, role-based deference, and diffusion of responsibility. Under those circumstances, employees tend to comply automatically. Therefore, it is highly likely that defensive measures that focus solely on awareness will be ineffective. Instead, more substantial modifications in terms of verification procedures, access policies, and distribution of responsibilities are needed.

Literature Review

Studies on social engineering have been moving away from the mere technical aspect towards considering human behavior within an organization (Wang et al., 2021). Recent studies have considered the attack as not being a random attempt but rather one that takes advantage of psychologically predictable behavior during manipulation (Steinmetz et al., 2021).

A considerable amount of literature relies on the principle of influence developed by Cialdini, including authority, liking, and urgency, which are found to recur the most in the attacks that succeed (Wang et al., 2021). Authority does not rely solely on official power but also on role-based perceptions. In situations where attackers assume roles consistent with regular processes, such as information technology support personnel, their demands are unlikely to be met with any scrutiny (Steinmetz et al., 2021). The element of liking is effective due to the establishment of brief rapport, which involves the use of common language or familiarity to minimize suspicion in brief conversations (Wang et al., 2021).

Whereas such explanations shed light on the creation of compliance, they fail to fully address the reasons behind the high effectiveness of internal impersonation. Social identity theory offers some clues to this regard; it appears that people tend to trust those who belong to the same organization (Mollazehi et al., 2024). Being recognized as an insider, one will be

trusted automatically. Such a trust can be explained by the authority bias, which means that people tend to obey authority in structured settings (Wang et al., 2021).

Organizational design also adds to vulnerabilities by virtue of responsibility dilution. When the task of ensuring security is shared among different people or processes, it results in lack of clarity and responsibility on the part of any individual to step in (Fischer et al., 2011; Siddiqi et al., 2022). There arises a discrepancy between perception and reality concerning security mechanisms.

More recent studies conducted into the capabilities of generative AI support the above points. Developments in content generation, customization, and speech synthesis make cyberattacks increasingly credible and difficult to identify (Schmitt & Flechais, 2024). The signals usually stressed in awareness training are losing their validity; besides, current security protocols are usually ill-equipped to combat such attacks using AI-based impersonation techniques (Pedersen et al., 2025).

In conclusion, the reviewed studies suggest that susceptibility to social engineering is not primarily caused by personal deficiencies but is the inevitable outcome of a patterned interaction between certain cognitive and organizational factors.

Case Study

The 2020 Twitter Compromise

The Twitter attack of July 15, 2020, unfolded over roughly twenty-four hours and began with targeted social engineering of employees (NYDFS, 2020). The attackers made contact with Twitter's employees over the phone and impersonated IT help desk personnel who could help with fixing problems related to virtual private networks (VPNs). Given the context of the ongoing pandemic in which Twitter had moved into working remotely, such tactics were highly successful. The victims were tricked into entering their credentials on the fake website.

Initial access came through regular employees, whose credentials the attackers then used to identify and target individuals with administrative privileges (NYDFS, 2020).

Using these tools, the attackers took over roughly forty-five high-profile accounts among the one hundred and thirty they had targeted, posting a coordinated cryptocurrency scam that pulled in about one hundred and eighteen thousand dollars in Bitcoin (NYDFS, 2020). The investigation found nothing technically advanced about the breach. What it did find was a set of organizational gaps the attackers were able to walk through: limited access controls, weak monitoring, and no centralized security leadership at the time of the attack.

The 2023 MGM Resorts Compromise

The September 2023 attack on MGM Resorts International was carried out by Scattered Spider, a financially motivated threat actor known to federal agencies as UNC3944 (CISA & FBI, 2023). Scattered Spider is known for its proficiency in social engineering techniques associated with help desks, leveraging publicly available employee information to carry out targeted phishing attacks and credential reset operations, followed by swift escalations.

At MGM, the initial breach took place following a phone call lasting approximately ten minutes. Scattered Spider first located an MGM employee via LinkedIn, compiled sufficient biographical information to impersonate them, and subsequently reached out to the help desk in search of assistance in accessing their accounts. The attacker successfully convinced the help desk representative to reset the user's credentials and register new multi-factor authentication factors, giving them full administrative access to the company's Okta and Azure ecosystems (CISA & FBI, 2023).

Following this access, the attackers deployed ransomware across MGM's network, taking down digital room keys, slot machines, reservation systems, and point-of-sale infrastructure across the company's Las Vegas properties for roughly ten days. The incident resulted in financial losses estimated at one hundred million dollars, along with a forty-five million dollar customer class action settlement reached in 2025. Caesars Entertainment, attacked through the same vector roughly a week earlier, reportedly paid the attackers, while MGM did not.

Cialdini's Principles of Influence

Research on social engineering consistently identifies authority, liking, and urgency as the principles most invoked in successful organizational compromises (Wang et al., 2021). Both the Twitter and MGM incidents reflect this pattern, though they operationalize the same principles in different configurations.

Authority played a central role in both cases but in slightly different ways. At Twitter, the attackers disguised themselves as IT Help Desk representatives, a position whose credibility employees trusted in solving problems related to gaining access (NYDFS, 2020). Authority stemmed from the position and not from any form of hierarchy. In the MGM incident, the dynamic was reversed, with the attacker disguising themselves as an employee requiring

assistance while relying on the authoritative cue of help desk employees being expected to offer their help (CISA & FBI, 2023). This request fit well into regular organizational activity and thus would likely not raise any suspicions. According to Steinmetz et al. (2021), authority in social engineering does not emanate purely from hierarchical structures but from roles played by actors within them.

Likeability and rapport also played a role in increasing compliance. The attackers at MGM found it easy to quickly establish rapport in just one phone call due to smooth communication and knowledge about workplace processes (CISA & FBI, 2023). In contrast, the lack of direct rapport with the Twitter attackers led them to exploit the existing frustrations of workers, such as the difficulties of using the VPN while working remotely (NYDFS, 2020). Minimal familiarity proved sufficient in reducing any level of suspicion. Urgency, however, amplified these elements of manipulation. The urgency factor was employed in both cases. In Twitter, employees thought that they needed to urgently act in order to solve their problems with the connection. In the case of MGM, urgency was already inherent in the help desk process since fast resolution was required to provide help. Across both incidents, verification was technically possible but consumed time the urgency cue made the target unwilling to spend (Siddiqi et al., 2022).

In-Group Trust and Authority Bias

In addition to persuasion, both cyberattacks involved other underlying processes of society and organizations: in-group trust and authority bias. When in-group trust takes place, people feel that another person belongs to their organization. Once such a perception is established, trust is the default. This process happened at Twitter, as the perpetrators pretended to be IT employees of the company dealing with a previously discussed problem. The same was

true for MGM, where perpetrators used information available on LinkedIn to appear like employees of the organization. The attackers appeared to belong, which reduced the felt need for verification (Mollazehi et al., 2024).

Awareness training often focuses on identifying external threats, but these attacks succeed precisely by appearing internal. When trust is based on perceived membership, awareness alone has limited effect, because the employee is not judging whether the person is external, but whether they seem internal (Siddiqi et al., 2022).

The concept of authority bias further strengthens this trend. It cannot be said that the employees are merely convinced to do certain things because of authority symbols; they have been taught to react in response to them. Within structured settings, conformity according to the role assumed, such as IT personnel, or an internal user's demands, is common practice. The workers at Twitter complied with directions from those who seemed like IT personnel to them. The MGM help desk employees followed procedure as per expectations for a user's request. Both instances showed compliance, which was natural considering the institutional setting involved. As seen in the social engineering literature incorporating Milgram's work (Wang et al., 2021), obedience to authority did not depend on personality types but situationally varied.

Diffusion of Responsibility

Diffusion of responsibility constitutes the fourth dynamic. This concept is rooted in the bystander intervention theory, as explained by Darley and Latané; this concept posits that where there is a distribution of responsibility among several respondents for a certain act, no single person is motivated enough to take part in the action (Fischer et al., 2011). Diffusion of responsibility applies to organizational verification procedures as well; where several individuals

are responsible for verifying an action or a request, everyone involved feels less personally responsible than they would have otherwise (Siddiqi et al., 2022).

At Twitter, responsibility was distributed across the workforce. No single employee bore specific responsibility for verifying that telephone calls from purported IT staff were legitimate; the responsibility was implicit in each employee's general security obligations and shared identically with every other employee receiving similar calls (NYDFS, 2020). When attackers placed multiple calls across multiple employees, the chance that any one employee would treat their call as needing extra verification was low. The NYDFS investigation found that initial compromises did not trigger organizational alerting that would have raised the verification threshold for subsequent calls.

At MGM, diffusion operated vertically through the workflow. The help desk agent who reset the targeted employee's credentials was operating within a process that distributed verification responsibility across multiple control points: identity questions at the call's outset, the credential reset action, the multi-factor authentication re-enrollment, and post-reset monitoring (CISA & FBI, 2023). When responsibility for detecting impersonation is distributed across multiple steps, each individual step bears less weight, and the agent at any given step can reasonably believe that other steps will catch what they do not. The federal advisory's recurring observation that help desk credential and multi-factor authentication reset workflows were the consistent vector of initial compromise across Scattered Spider intrusions indicates that this diffusion pattern is widespread rather than specific to MGM.

A Critical Perspective on Awareness-Based Defense

Reflecting on these four mechanisms highlights a broader limitation in what cybersecurity training can achieve. The primary approach to defense that is used in

organizational settings depends on the idea that educated staff will be more capable of protecting themselves against social engineering. This assumption seems to be based on flawed logic according to the recent research and the cases presented above. The cases show that compliance takes place despite employees' knowledge of social engineering dangers due to favorable conditions (Siddiqi et al., 2022).

Awareness training is just a partial solution. It deals with decision making at the individual level, but the vulnerability exists structurally. When an employee faces authority-based cues, in-group trust, and time pressure, they will react accordingly despite knowing about it, because the underlying behaviors are not corrected by information alone (Siddiqi et al., 2022; Wang et al., 2021). Recent studies conducted in the realm of AI-powered social engineering also corroborate this viewpoint. As Schmitt & Flechais (2024) reveal through their systematic review, the development of generative AI poses serious threats to awareness training by removing all those cues from the scenario that awareness training had used. A study conducted in the year 2025 showed that awareness training was insufficient for identifying the deception carried out with the help of synthetic media (Pedersen et al., 2025).

When taken into account, all these indicate the existence of a genuine problem with today's cybersecurity practices. These usually place too much confidence in human resilience while underestimating the power of organizational structure and technological advances. The solution for addressing social engineering lies precisely in making this shift in emphasis possible.

Synthesis: Structural Vulnerability and Defensive Implications

Both cases reveal a certain regularity that goes beyond just the actions of specific employees. In both scenarios, four psychological processes occurred at once: persuasion techniques produced the pressure for compliance, in-group trust made the credibility barrier less

effective, authority bias provided an organizationally rooted tendency towards compliance, and diffusion of responsibility ensured that nobody was individually accountable for performing the one thing that would prevent the situation from developing into a breach. This combination of processes did not happen by chance, but rather as a result of how people behave within organizations.

Three types of intervention follow from this analysis. First, access requests need to be independently verified through pre-established out-of-band channels rather than resolved within a single interaction (Siddiqi et al., 2022). Second, identity verification should move away from biographical details that can be pulled from social media and toward cryptographic methods, such as phishing-resistant hardware security keys, that neutralize the attack at the protocol level. Third, verification responsibility needs to sit with specifically named, accountable roles instead of being spread across multiple workflow steps, where diffusion of responsibility predictably creates the gaps attackers exploit.

Both companies moved in this direction after the fact, with Twitter rolling out phishing-resistant hardware security keys (NYDFS, 2020) and MGM reportedly committing forty million dollars to identity and access management. A second implication concerns the limits of attacker sophistication as an explanatory variable. In both cases, the perpetrators were young and used methods that required no novel exploitation and no advanced technical capability (NYDFS, 2020; CISA & FBI, 2023). The attacks worked not because the attackers were exceptional, but because the targets were operating in conditions where ordinary persuasion applied to ordinary cognitive habits produced predictable results.

Conclusion

While there is a three-year gap between the Twitter 2020 and MGM Resorts 2023 incidents, as well as a shift in industry sectors from one to the other, there is a common thread between the two events that must be considered. The two compromises were facilitated by pretextual telephone calls designed to exploit the predictable behavior of employees working in environments that foster compliance over verification. The defensive takeaway from this is that organizations cannot train their way out of being victims of social engineering attacks. Rather, the four psychological factors revealed in this study are not a function of faulty individual decision-making that can be improved through better information. They are inherent aspects of human cognition in organizational settings that can only be addressed through redesigning the processes in which credentials and access decisions are made, eliminating the circumstances in which they lead to compromise. It is telling that both Twitter and MGM have taken steps toward achieving this goal after their respective experiences, pointing toward consensus on the issue despite a lack of clarity on its full implications.

References

- Cybersecurity and Infrastructure Security Agency, & Federal Bureau of Investigation. (2023, November 16). *Scattered Spider (Joint Cybersecurity Advisory AA23-320A)*.
<https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-320a>
- Fischer, P., Krueger, J. I., Greitemeyer, T., Vogrincic, C., Kastenmüller, A., Frey, D., Heene, M., Wicher, M., & Kainbacher, M. (2011). The bystander-effect: A meta-analytic review on bystander intervention in dangerous and non-dangerous emergencies. *Psychological Bulletin*, 137(4), 517–537. <https://doi.org/10.1037/a0023304>
- Mollazehi, A., Abuelezz, I., Barhamgi, M., Khan, K. M., & Ali, R. (2024). Do Cialdini's persuasion principles still influence trust and risk-taking when social engineering is knowingly possible? In *Research Challenges in Information Science* (pp. 273–288). Springer Nature. https://doi.org/10.1007/978-3-031-59465-6_17
- New York State Department of Financial Services. (2020, October 14). *Report on investigation of Twitter's July 15, 2020 cybersecurity incident and the implications for election security*. https://www.dfs.ny.gov/Twitter_Report
- Pedersen, K. T., Pepke, L., Stærmose, T., Papaioannou, M., Choudhary, G., & Dragoni, N. (2025). Deepfake-driven social engineering: Threats, detection techniques, and defensive strategies in corporate environments. *Journal of Cybersecurity and Privacy*, 5(2), Article 18. <https://doi.org/10.3390/jcp5020018>
- Schmitt, M., & Flechais, I. (2024). Digital deception: Generative artificial intelligence in social engineering and phishing. *Artificial Intelligence Review*, 57, Article 324.
<https://doi.org/10.1007/s10462-024-10973-2>

Siddiqi, M. A., Pak, W., & Siddiqi, M. A. (2022). A study on the psychology of social engineering-based cyberattacks and existing countermeasures. *Applied Sciences*, 12(12), Article 6042. <https://doi.org/10.3390/app12126042>

Steinmetz, K. F., Pimentel, A., & Goe, W. R. (2021). Performing social engineering: A qualitative study of information security deceptions. *Computers in Human Behavior*, 124, Article 106930. <https://doi.org/10.1016/j.chb.2021.106930>

Wang, Z., Zhu, H., & Sun, L. (2021). Social engineering in cybersecurity: Effect mechanisms, human vulnerabilities, and attack methods. *IEEE Access*, 9, 11895–11910. <https://doi.org/10.1109/ACCESS.2021.3051633>